MDM GRC READINESS & CONTROL ASSURANCE CASE STUDY

MDM-D04

Risk Assessment Methodology and Risk Register

Deliverable 4 of 15 in a portfolio case study on readiness and control assurance for mobile access to Microsoft 365 at a fictional 850-employee Saudi financing company. Cross-references to other deliverables use their MDM-D numbers.

Prepared by

Ali Fathi Aldhabiki

Cybersecurity Governance, Risk & Compliance (GRC)

linkedin.com/in/ali-aldhabiki-a74354212 | ali.f.aldhabiki@outlook.com

Notice

The organization is fictional. No Microsoft Intune or Entra ID tenant was configured; all evidence, test results and ratings are simulated.

Risk Assessment Methodology and Risk Register

MDM-D04

Impact Criteria

Score	Impact level	Description
1	Insignificant	Brief individual disruption with a workaround; no sensitive data exposure or material business harm.
2	Minor	Limited disruption or easily corrected changes to low-sensitivity information; minor business harm.
3	Moderate	Team-level disruption, confidential data exposure, or record changes causing meaningful but contained harm.
4	Major	Significant disruption to important activities or serious harm from sensitive data exposure or unauthorized record changes.
5	Severe	Critical activities prevented, extensive highly sensitive data exposure, or critical record corruption causing severe harm.

Use the highest applicable confidentiality, integrity, or availability impact score and document the rationale.

Likelihood Criteria

Score	Likelihood Level	Description
1	Rare	Requires exceptional circumstances; exposure and opportunities are very limited.
2	Unlikely	Plausible but not expected; exposure is limited and several conditions must coincide.
3	Possible	Could occur under realistic conditions; exposure and an opportunity exist.
4	Likely	Expected under common conditions; exposure is frequent and barriers are limited.
5	Almost Certain	Expected repeatedly or imminently; exposure is persistent and barriers are minimal.

Assess likelihood over the next 12 months and document the rationale. Credit existing controls only where their effectiveness is supported by evidence.

Risk Scoring and Classification

Risk Score = Likelihood × Impact

Risk Score	Risk Level
1–4	Low
5–9	Medium
10–16	High
17–25	Critical

Any risk with an Impact score of 5 requires management review regardless of its overall score. The calculated risk level remains unchanged. A Low rating does not imply automatic risk acceptance.

These scoring thresholds are defined for this case study and are not regulatory requirements.

Risk Assessment Basis

Assessment Type	Assessment Basis
Inherent Risk	Risk assessed without crediting controls that address the scenario.
Current Residual Risk	Risk remaining after considering existing controls whose effectiveness is supported by evidence. Mark as “Not assessed” until reviewed.
Target Residual Risk	Expected risk after planned treatment, assuming controls operate effectively. Subject to validation through testing.

Document the likelihood, impact, score, and rationale for each assessment. Planned controls do not justify reducing current residual risk. Update the current assessment after testing or retesting, retaining previous results for traceability.

Risk Ownership

Each risk is assigned a Risk Owner: the role accountable for the business consequences of the risk and authorized to decide its treatment. The Risk Owner approves the treatment approach and target residual risk, and receives testing results affecting the risk. Control owners in MDM-D05 are accountable for control design and operation and may differ from the Risk Owner. Risk acceptance follows the corporate risk acceptance process. Risk Owner assignments in this case study are project-defined.

Risk Register

The register holds eight risks. The table summarizes them; a detailed record for each risk follows. Residual ratings come from MDM-D12 Section 4.

Risk ID	Risk Title	Risk Owner	Inherent Risk	Current Residual	Target Residual
MDM-RSK-001	Unauthorized Access to Data on a Lost Corporate Device	Business Owner	Medium (9)	Medium (6)	Low (3)
MDM-RSK-002	Corporate Data Leakage to Personal Apps or Accounts	Business Owner	High (12)	Medium (9), provisional	Medium (8)
MDM-RSK-003	Corporate Data Exposure Through Non-Compliant Devices	Business Owner	Medium (9)	Medium (6)	Medium (6) until D-01 is decided
MDM-RSK-004	Business Disruption Due to Incorrect Access Policy Changes	Business Owner	Medium (6)	Not assessed	-
MDM-RSK-005	Unauthorized Changes to Centralized Device Security Settings	CISO	High (12)	Medium (6)	Low (3)
MDM-RSK-006	Inappropriate Internal Access to Employee Device Reports	CISO	Medium (6)	Not assessed	-
MDM-RSK-007	Continued Corporate Access After Contractor Departure	Business Owner	Medium (9)	Medium (6)	Low (3)
MDM-RSK-008	Inaccurate Device Compliance Reporting	CISO	Medium (6)	Not assessed	-

"Not assessed" means the related controls were outside the test sample in MDM-D10.

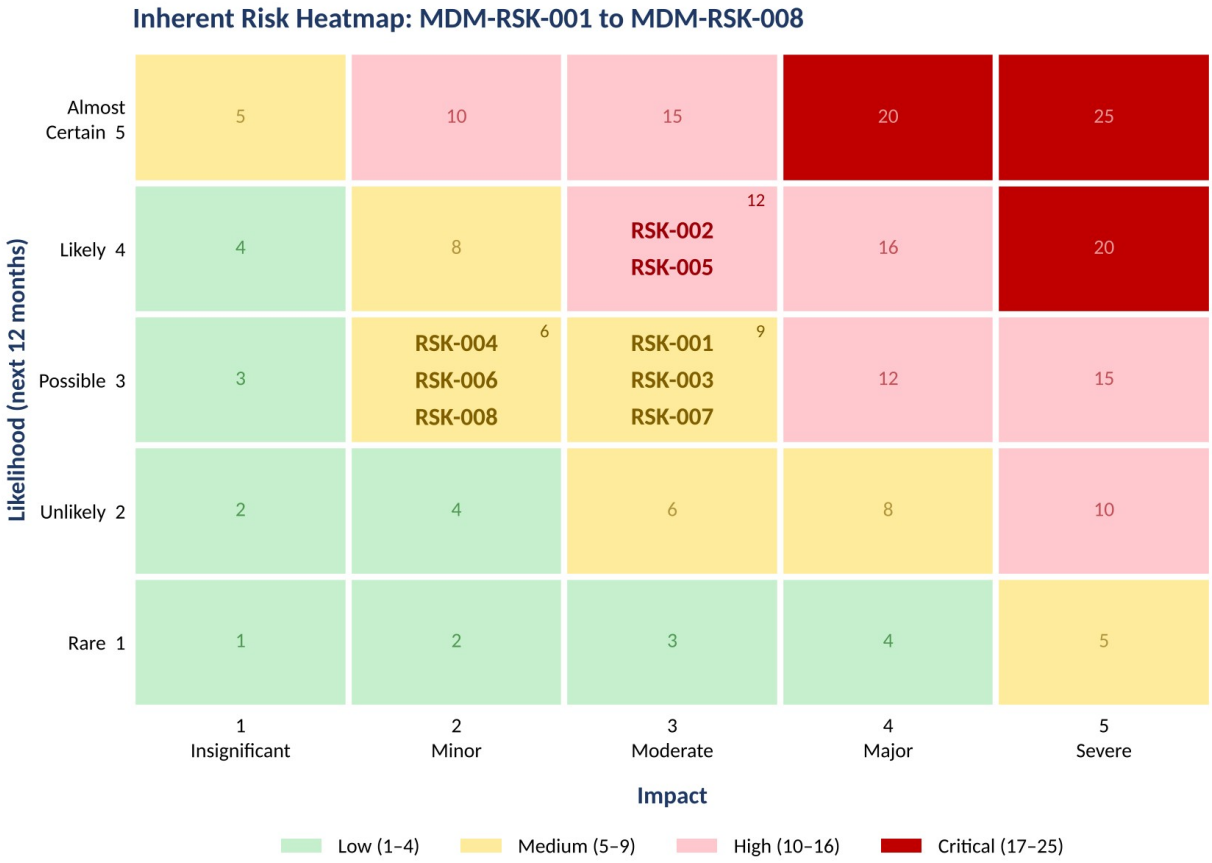


Figure 1. Inherent risk heatmap. Positions use the likelihood and impact scores in each risk record below.

Risk ID

MDM-RSK-001

Field	Details
Risk Title	Unauthorized Access to Data on a Lost Corporate Device
Risk Statement	If a company-owned mobile device is lost or stolen, an absent or weak device passcode may allow an unauthorized person to access corporate information, resulting in a confidentiality breach and potential financial or reputational harm.
Related Assets	MDM-AST-001; MDM-AST-004; MDM-AST-003
Risk Owner	Business Owner
Primary CIA Impact	Confidentiality
Scenario Assumption	A corporate device is routinely used off-site and contains or can access a limited set of confidential internal work

Field	Details
	documents.
Inherent Impact	3 - Moderate
Impact Rationale	Exposure of a limited set of confidential internal work documents could cause meaningful but contained business harm.
Inherent Likelihood	3 - Possible
Likelihood Rationale	Routine off-site use creates opportunities for device loss or theft, while weak or absent passcode protection makes subsequent unauthorized access plausible within 12 months.
Inherent Risk Score	9
Inherent Risk Level	**Medium**
Current Residual Risk	Medium (6). MDM-D12 Section 4, 16 November 2026.
Target Residual Risk	**Low (3). MDM-D12 Section 4, 16 November 2026.**

Risk ID

MDM-RSK-002

Field	Details
Risk Title	Corporate Data Leakage to Personal Apps or Accounts
Risk Statement	Missing or misconfigured data transfer restrictions may allow employees to copy or save confidential work documents to personal apps or accounts on BYOD devices, resulting in loss of organizational control over the documents and potential unauthorized disclosure.
Related Assets	MDM-AST-005; MDM-AST-006; MDM-AST-003; MDM-AST-002
Risk Owner	Business Owner
Primary CIA Impact	Confidentiality
Scenario Assumption	Employees frequently handle confidential work documents on BYOD devices, where personal apps and storage accounts are readily available.

Field	Details
Inherent Impact	3 - Moderate
Impact Rationale	Exposure of a limited set of confidential internal work documents could cause meaningful but contained business harm.
Inherent Likelihood	4 - Likely
Likelihood Rationale	Frequent document handling and readily available personal storage make transfers outside approved apps likely within 12 months when transfer restrictions are ineffective.
Inherent Risk Score	12
Inherent Risk Level	**High**
Current Residual Risk	Medium (9), provisional. MDM-D12 Section 4, 16 November 2026.
Target Residual Risk	Medium (8). MDM-D12 Section 4, 16 November 2026.

Risk ID

MDM-RSK-003

Field	Details
Risk Title	Corporate Data Exposure Through Non-Compliant Devices
Risk Statement	Missing or misconfigured access restrictions may allow non-compliant devices to access corporate services, potentially exposing confidential work documents to unauthorized parties if a device is compromised.
Related Assets	MDM-AST-001; MDM-AST-004; MDM-AST-003; MDM-AST-002; MDM-AST-007; MDM-AST-008
Risk Owner	Business Owner
Primary CIA Impact	Confidentiality
Scenario Assumption	A corporate device with an outdated OS and an exploitable vulnerability can access confidential work documents through Microsoft 365 despite failing security requirements.
Inherent Impact	3 - Moderate

Field	Details
Impact Rationale	Exposure of a limited set of confidential internal work documents could cause meaningful but contained business harm.
Inherent Likelihood	3 - Possible
Likelihood Rationale	An exploitable OS vulnerability combined with continued access to corporate services makes device compromise and subsequent document exposure plausible within 12 months.
Inherent Risk Score	9
Inherent Risk Level	**Medium**
Current Residual Risk	Medium (6). MDM-D12 Section 4, 16 November 2026.
Target Residual Risk	Medium (6) until D-01 is decided. MDM-D12 Section 4, 16 November 2026.

Risk ID

MDM-RSK-004

Field	Details
Risk Title	Business Disruption Due to Incorrect Access Policy Changes
Risk Statement	Inadequate testing of access policy changes before deployment may block authorized employees from accessing corporate services, disrupting business tasks that depend on email and work documents.
Related Assets	MDM-AST-001; MDM-AST-004; MDM-AST-005; MDM-AST-006; MDM-AST-007; MDM-AST-008
Risk Owner	Business Owner
Primary CIA Impact	Availability
Scenario Assumption	An incorrect access policy blocks one team's mobile access to Microsoft 365 for several hours. Corporate computers remain available for most tasks.
Inherent Impact	2 - Minor
Impact Rationale	Corporate computers provide an alternative way to continue most tasks, limiting the disruption to minor delays in one

Field	Details
	team's work.
Inherent Likelihood	3 - Possible
Likelihood Rationale	Inadequate testing creates a plausible opportunity for an access policy error to reach deployment and block legitimate mobile access within 12 months.
Inherent Risk Score	6
Inherent Risk Level	**Medium**
Current Residual Risk	Not assessed; controls not tested. MDM-D12 Section 4, 16 November 2026.
Target Residual Risk	**Not set until tested. MDM-D12 Section 4.**

Risk ID

MDM-RSK-005

Field	Details
Risk Title	Unauthorized Changes to Centralized Device Security Settings
Risk Statement	Excessive administrative privileges may allow users to make unauthorized changes to Intune security settings, weakening protection across affected corporate devices.
Related Assets	MDM-AST-002; MDM-AST-001; MDM-AST-004
Risk Owner	CISO
Primary CIA Impact	Integrity
Scenario Assumption	Several staff members with excessive administrative privileges modify configurations daily without independent review. A change disables passcode enforcement across most corporate devices; existing passcodes are not removed.
Inherent Impact	3 - Moderate
Impact Rationale	Unauthorized removal of passcode enforcement compromises the approved security configuration across corporate devices and requires coordinated restoration and verification. The scenario assumes meaningful but contained

Field	Details
	operational harm.
Inherent Likelihood	4 - Likely
Likelihood Rationale	Daily changes by multiple staff with excessive privileges and no independent review make unauthorized configuration changes likely within 12 months.
Inherent Risk Score	12
Inherent Risk Level	**High**
Current Residual Risk	Medium (6). MDM-D12 Section 4, 16 November 2026.
Target Residual Risk	**Low (3). MDM-D12 Section 4, 16 November 2026.**

Risk ID

MDM-RSK-006

Field	Details
Risk Title	Inappropriate Internal Access to Employee Device Reports
Risk Statement	Overly broad access permissions on a shared folder may allow employees without a business need to view colleagues' personal data in device management reports, compromising data confidentiality and employee privacy.
Related Assets	MDM-AST-009; MDM-AST-002
Risk Owner	CISO
Primary CIA Impact	Confidentiality
Scenario Assumption	An internally shared report contains only employee names, work email addresses, device models and compliance statuses, and is accessible to staff without a business need.
Inherent Impact	2 - Minor
Impact Rationale	Internal exposure of limited employee identifiers and device details is expected to cause minor privacy harm.
Inherent Likelihood	3 - Possible
Likelihood Rationale	Broad folder permissions make unauthorized internal

Field	Details
	viewing plausible within 12 months, although frequent browsing or direct distribution is not assumed.
Inherent Risk Score	6
Inherent Risk Level	**Medium**
Current Residual Risk	Not assessed; controls not tested. MDM-D12 Section 4, 16 November 2026.
Target Residual Risk	**Not set until tested. MDM-D12 Section 4.**

Risk ID

MDM-RSK-007

Field	Details
Risk Title	Continued Corporate Access After Contractor Departure
Risk Statement	Delayed notification of a contractor's departure to IT may leave access active after the contract ends, allowing unauthorized viewing or disclosure of corporate information and, where editing permissions remain, unauthorized modification of documents.
Related Assets	MDM-AST-001; MDM-AST-004; MDM-AST-003; MDM-AST-007; MDM-AST-008
Risk Owner	Business Owner
Primary CIA Impact	Confidentiality
Scenario Assumption	A former contractor retains access from a company-issued device for several days after departure, including access to confidential routine team documents and permission to edit some of them.
Inherent Impact	3 - Moderate
Impact Rationale	Unauthorized disclosure or modification of confidential team documents could cause meaningful but contained harm, including rework and limited delays.
Inherent Likelihood	3 - Possible
Likelihood Rationale	Access remaining active for several days after departure

Field	Details
	gives a former contractor an opportunity to view, disclose or modify corporate documents without authorization within the assessment period.
Inherent Risk Score	9
Inherent Risk Level	**Medium**
Current Residual Risk	Medium (6). MDM-D12 Section 4, 16 November 2026.
Target Residual Risk	**Low (3). MDM-D12 Section 4, 16 November 2026.**

Risk ID

MDM-RSK-008

Field	Details
Risk Title	Inaccurate Device Compliance Reporting
Risk Statement	Errors in manually matching device records may assign compliance statuses to the wrong devices, resulting in inaccurate reporting, misdirected follow-up and delays in corrective action.
Related Assets	MDM-AST-009
Risk Owner	CISO
Primary CIA Impact	Integrity
Scenario Assumption	A manually compiled device compliance report is used by one team for routine operational follow-up.
Inherent Impact	2 - Minor
Impact Rationale	Incorrect device compliance information causes misdirected follow-up, limited operational delays and rework to correct the report.
Inherent Likelihood	3 - Possible
Likelihood Rationale	Manual matching of device records creates a plausible opportunity for errors that affect operational follow-up within the 12-month assessment period.
Inherent Risk Score	6

Field	Details
Inherent Risk Level	**Medium**
Current Residual Risk	Not assessed; controls not tested. MDM-D12 Section 4, 16 November 2026.
Target Residual Risk	**Not set until tested. MDM-D12 Section 4.**